

SC EXAM PREP — PREDICTED 2026

マルウェア・攻撃手法・インシデント対応

MITRE ATT&CK／ランサムウェア／EDR/XDR/MDR／フォレンジック。侵入から横展開・被害・検知・証拠保全までの「攻防のライフサイクル」を5問で体系学習する。

Q1・Framework

**MITRE ATT&CK の TTP
3階層**

頻出 ★★★

Q2・Ransomware

イミュータブルバックアップ運用

頻出 ★★★

Q3・Detection

EDR / XDR / MDR の違い

頻出 ★★★

Q4・Forensics

揮発性の順序(Order of Volatility)

頻出 ★★★

Q5・Lateral

Pass the Hash による横展開

頻出 ★★★

 基礎概念 5枚  問題演習 5問  統合サマリー  2026 春・秋 想定

※ 過去問傾向(令和3～7年)と最新動向をもとにAIが作成した予想問題です。実際の試験問題ではありません。最終確認を推奨します。



学習マップ — 5問の相互関係

MAP

「共通言語 → 侵入・横展開 → 被害 → 検知 → 証拠保全」の攻防ライフサイクル

Q1

ATT&CK

攻撃者の振る舞いを
Tactics/Techniques/Procedures
で体系化。全問の共通言語

Framework / 定義問題



Q5

横展開

Pass the Hash で平文復元
なしに他システムへ認証。
Lateral Movement

攻撃技法 / T1550.002



Q2

ランサム

暗号化+窃取。バックアップ
も破壊される→イミュータブル/
オフライン

Impact / 3-2-1



Q3

検知/対応

EDR→XDR(横断相
関)→MDR(運用代行)。検
知・封じ込め基盤

SOC / 監視体制



Q4

保全

揮発性の高い順(メモリ→デ
ィスク)に証拠保全。ライブ
採取が要

Forensics / 事後対応

STEP 1 | WHY

攻撃を「戦術×技法(TTP)」で捉え、キルチェーン
との違いと攻防の全体像を掴む

STEP 2 | HOW

5問で「攻撃技法/検知製品/保全原則」を判別
し、混同ひっかけを切る

STEP 3 | WHAT

空-雨-傘で対策(MFA・イミュータブル・振る舞い
検知・ライブ保全)へ落とす

① 基礎概念 — 攻撃ライフサイクルと本デッキの配置

キルチェーン(線)× ATT&CK 戦術(面)の2軸で5問と主要技法を俯瞰

CONCEPT

キルチェーン段階	対応する ATT&CK 戦術(例)	代表技法・本デッキ論点
配送・エクスプロイト	Initial Access	VPN 不正ログイン(MFA未導入・パスワード使い回し)/フィッシング
インストール・C2	Execution / Command & Control	正規プロセスからの PowerShell 実行(LotL)/コネクトバック通信
目的の実行(内部活動)	Credential Access / Lateral Movement	LSASS ダンプ/Q5 Pass the Hash(T1550.002)=横展開
目的の実行(被害)	Impact	Q2 ランサムウェア(二重脅迫)/バックアップ暗号化
検知・対応・事後	Detection / Response(防御側)	Q3 EDR/XDR/MDR / Q4 フォレンジック(揮発性順) / 全体を Q1 ATT&CK で整理

核心: キルチェーンは偵察～目的実行を並べた直線(線)のモデル、ATT&CK は順序を前提としない網羅マトリクス(面)。攻撃の各段階を Q1 ATT&CK の戦術で言語化し、被害(Q2)・検知(Q3)・保全(Q4)・横展開(Q5)を配置すると全体像が一枚で見える。

② 基礎概念 — 混同しやすい概念 比較表

似て見えるが「役割・段階・対象」が異なる5ペア

CONCEPT

対象概念	● 概念A	● 概念B (混同パターン)
攻撃モデル	キルチェーン：偵察～目的実行を直線的に順序づけた「線」のモデル	ATT&CK：順序を前提としない網羅的な手法辞書「面」(マトリクス)
TTP の階層	Tactics=目的(What)/Techniques=手段(How)：汎用的な手法分類	Procedures/IOC：特定攻撃者の具体実装や IP・ハッシュ等の個別指標
PtH の戦術	取得済みハッシュの再利用 = Lateral Movement/Defense Evasion	ハッシュをダンプする行為自体 = Credential Access(取り違え注意)
監視の範囲	EDR：エンドポイントの検知・対応/XDR：NW・クラウド・ID まで横断相関	SIEM = ログ収集・相関の製品/SOAR = 対応自動化(いずれも別概念)
バックアップ	イミュータブル+オフライン/エアギャップ+3-2-1で隔離保管	本番と同一 NAS に常時オンライン保存 = 暗号化が同時波及

TTP Tactics / Techniques / Procedures

Tactics=目的(What)、Techniques=手段(How)、Procedures=特定攻撃者の具体的実装。
1技法は複数戦術に属し得る。

 **MITRE ATT&CK****二重脅迫 Double Extortion**

暗号化に加えデータを窃取し、支払わなければ公開すると脅す手口。単なる「ランサムウェア」では不可。

 **ランサム最新動向****EDR / XDR / MDR**

EDR=端末の検知・対応、XDR=EDRをNW/クラウド/ID等へ拡張し横断相関、MDR=監視・運用を外部が代行。

 **検知・運用****Pass the Hash Pth**

NTLMハッシュ等をそのまま認証に再利用し、平文復元なしで横展開。ATT&CK では T1550.002。

 **T1550.002****IOC Indicator of Compromise**

IPアドレス・ファイルハッシュ等の侵害指標。Techniques より低抽象度で個別的。Techniques と混同しない。

 **侵害指標****イミュータブルバックアップ Immutable / WORM**

書き換え・削除ができない保存。3-2-1(3世代・2媒体・1拠点分離)+オフライン/エアギャップが定石。

 **3-2-1 ルール****揮発性の順序 Order of Volatility**

揮発性の高い順(CPUレジスタ/キャッシュ→メモリ→ディスクログ→媒体)に保全。電源断で消える情報を優先。

 **証拠保全の原則****Living off the Land LotL**

PowerShell 等の正規ツールを悪用する手法。シグネチャを回避するため振る舞い検知が有効。

 **正規ツール悪用**

④ 基礎概念 — フレームワーク・ツールマトリクス

「攻撃体系／防御体系／検知製品／可視化ツール」を混同しない

CONCEPT

名称	種別	要点（試験での問われ方）
MITRE ATT&CK	攻撃TTPの体系化(面)	実観測の攻撃者の振る舞いを戦術×技法で網羅。 Q1の題材 。順序を前提としないマトリクス。
サイバーキルチェーン	攻撃段階モデル(線)	偵察～目的実行を直線的な7段階で示す。ATT&CKとは相補的に併用(排他ではない)。
MITRE D3FEND	防御技術の体系化	対策側のマッピング 。攻撃TTPの体系化ではない=キルチェーン/ATT&CKとの取り違えに注意。
ATT&CK Navigator	可視化ツール	自社検知ルールがどの技術をカバーし空白があるかを可視化。午後問2の解。SIEM/SOARは不可。
EDR / XDR	検知・対応 製品	EDR=端末、XDR=横断相関。 Q3の題材 。振る舞い検知でLotL/未知亜種に対応。
MDR / SOC	監視・運用サービス	EDR/XDRの監視・運用を専門ベンダが24時間代行。SIEM(製品)・SOAR(自動化)とは別。

💡 **頻出の軸:** 「攻撃を体系化=ATT&CK/キルチェーン」 「防御を体系化=D3FEND」 「検知製品=EDR/XDR」 「運用代行=MDR」 「カバレッジ可視化=Navigator」。この取り違えが4択・午後のひっかけの定番。



試験のコツ & 頻出ひっかけ

Exam Strategy & Common Pitfalls

TIPS

✓ 解くコツ

1. ATT&CK は **What=Tactics / How=Techniques / 実装=Procedures** の3階層。番号は Tactics=TA、Techniques=T。
2. 横展開の技法(PtH)は取得済みハッシュの「再利用」=Lateral Movement。ダンプ行為(Credential Access)と分ける。
3. ランサム対策はイミュータブル+オフライン(エアギャップ)+**3-2-1**が正解語彙。
4. フォレンジックは揮発性の高い順=メモリ→ディスク→媒体。ライブ(活性)採取を優先。

⚠ よくあるひっかけ

- EDR と XDR の説明を逆にする／SIEM(収集)・SOAR(自動化)をEDRと混同。
- バックアップを「本番と同一NASに常時オンライン」=同時暗号化で復旧不可。
- PtHで「平文パスワードを復元して」と書く選択肢=復元しないのが本質。
- 「単なるランサムウェア」で二重脅迫を答える／保全で先に電源を切る=揮発情報消失。

合言葉: 「攻撃は TTP で言語化」→ 対策は「**MFA**・イミュータブル/オフライン・横断相関(XDR)・振る舞い検知・ライブ保全」の5語彙に集約される。

MITRE ATT&CK(Enterprise)における Tactics、Techniques、Procedures(TTP)の関係の説明として、適切なものはどれか。

ア Procedures は攻撃者の最終目的を表す最上位の分類であり、その下位に Tactics と Techniques が位置づけられる

イ Tactics は達成しようとする目的(What)、Techniques はその手段(How)を表し、個々の攻撃者による具体的な実装が Procedures である

ウ Techniques は個別の攻撃で観測された IP アドレスやファイルハッシュなどの侵害指標(IOC)そのものを指す

エ Tactics は T 番号、Techniques は TA 番号で識別され、両者は 1 対 1 に対応する

正解 イ ア=階層が逆/ウ=IOCはProceduresより個別・低抽象度/エ=番号割当が逆かつ1対1でない

空 (事実)

Tactics=目的(What)、Techniques=手段(How)、Procedures=特定攻撃者の具体的実装、という3階層。

雨 (解釈)

識別子は Tactics=TA、Techniques=T(サブは T####.###)。1技法は複数戦術に属し得るため1対1ではない。

傘 (対策)

TTP を共通言語に脅威分析を行い、汎用手法(Techniques)と個別指標(IOC/Procedures)を分けて整理する。

ランサムウェアによる被害拡大を防ぐためのバックアップ運用として、最も効果が高いものはどれか。

ア バックアップデータを本番サーバと同一のファイルサーバ上の別フォルダに毎時保存する

イ 書き換え・削除ができないイミュータブル(改変不可)ストレージへ保存し、あわせてオフラインの複製を保持する

ウ バックアップ管理者と本番システム管理者に同一の特権アカウントを共有させ、復旧を迅速化する

エ ネットワーク上で常時オンラインの単一の共有ストレージに世代を集約し、容量効率を最優先する

正解 イ ア・エ=常時オンライン・同一系統で同時波及/ウ=特権共有で一括破壊リスク増

空 (事実)

近年のランサムウェアはバックアップの探索・破壊を定石とする。

雨 (解釈)

書き換え・削除不可のイミュータブル、3-2-1(3世代・2媒体・1拠点分離)、オフライン/エアギャップが有効。

傘 (対策)

イミュータブル/WORM保存+オフライン隔離複製。特権アカウントは分離し一括破壊を防ぐ。

実務メモ: 午後のランサム設問で頻出。「バックアップが本番と同一・オンライン・書き換え可能」だった点を復旧失敗の要因として特定できるかが分水嶺。

EDR、XDR、MDR の説明の組合せとして、適切なものはどれか。

ア EDR はネットワーク・クラウド・メール・ID まで横断的に相関分析する仕組みであり、XDR はエンドポイント単体に限定した監視である

ウ MDR はログを収集・相関する製品(SIEM)そのものを指し、EDR/XDR とは無関係である

イ XDR は EDR の監視範囲をエンドポイント外へ拡張し横断的に相関分析する仕組みであり、MDR はそれらの監視・運用を外部が代行するサービスである

エ EDR は対応を自動化するプレイブック実行基盤(SOAR)の別称であり、XDR はその上位互換である

正解 イ ア=EDRとXDRの説明が逆/ウ=SIEMは別概念/エ=SOARは別概念

空 (事実)

EDR=エンドポイントの監視・検知・対応、XDR=EDRを端末外へ拡張し横断相関。

雨 (解釈)

MDR=これらの監視・運用を専門ベンダが代行するサービス。SIEM(収集)・SOAR(自動化)とは別。

傘 (対策)

端末はEDR、横断相関はXDRで補い、自社に人的リソースが無ければMDRで24時間監視を委託。

インシデント対応におけるデジタルフォレンジックスで、揮発性の高い情報から順に証拠保全を行う原則(**Order of Volatility**)に従うとき、最も優先して取得すべきものはどれか。

ア ハードディスク上のログファイル

イ **CPU レジスタ・キャッシュおよびメモリ上の情報**

ウ 定期バックアップ用の磁気テープ

エ 監視カメラの録画データ

正解 イ 揮発性の高い順＝メモリ→ディスクログ(ア)→バックアップ媒体(ウ)→物理記録(エ)

▲ 空 (事実)

CPUレジスタ・キャッシュ・メモリ上の情報は電源断で失われる。

☂ 雨 (解釈)

メモリには実行中プロセス・NW接続状態・復号された暗号鍵が含まれ、最優先で保全すべき。

☂ 傘 (対策)

電源を切らず**活性(ライブ)状態**で揮発性情報から採取し、以降ディスク・媒体の順で保全する。

攻撃者が窃取済みの認証情報のハッシュ値を用い、平文パスワードを復元することなく他システムへ認証を通す横展開(Lateral Movement)の手法はどれか。

ア Pass the Hash

イ DNS リフレクション攻撃

ウ クリプトジャッキング

エ ディレクトリトラバーサル

正解 ア イ=DNS悪用のDRDoS/ウ=無断マイニング/エ=想定外ファイルへの不正アクセス

▲ 空 (事実)

NTLMハッシュ等をそのまま認証に再利用し、平文復元なしで他システムへ認証を通す。

☂ 雨 (解釈)

ATT&CK では T1550.002。ハッシュの再利用=Lateral Movement/Defense Evasion。ダンプ行為(Credential Access)と分ける。

☂ 傘 (対策)

LSASS保護・特権分離・NTLM制限・管理者ログオン制限、EDRでの認証情報アクセス検知。

👜 実務メモ: 取得済みハッシュの再利用が横展開/防御回避、ダンプ行為自体が Credential Access。この戦術の区別を問う選択肢が定番のひっかけ。



午後 記述式 — シナリオ要点

ランサムウェアIR / SOC 検知強化・フォレンジック

記述

◆ 問1 (秋想定) ランサムウェアIR

- 暗号化+窃取・暴露で金銭要求 → **二重脅迫(ダブルエクストーション)**。「ランサムウェア」だけでは不可。
- 侵入要因(認証観点) = **VPNにMFA未導入(単要素)** + パスワード使い回し(漏えい済み認証情報の悪用)。
- 復旧失敗 = バックアップが**本番と同一NAS**にオンライン・書換可で同時暗号化。改善 = イミュータブル + オフライン/3-2-1。
- ATT&CK戦術: LSASSダンプ = **Credential Access** / RDP他サーバ接続 = **Lateral Movement**。

◆ 問2 (春想定) SOC検知・フォレンジック

- 感染端末から外部C2へ自ら接続 → **コネクトバック通信**。境界FWは内→外を広く許可し正規通信に紛れ通過。
- 隔離後に電源を切らず**ライブ保全** = メモリ・NW接続・復号鍵は電源断で消失(Order of Volatility)。
- 正規プロセスからのPowerShell難読化実行 = **振る舞い(挙動)検知**。LotL型はシグネチャ回避のため連鎖を評価。
- 検知カバレッジと空白の可視化 = **ATT&CK Navigator**(SIEM/SOARは不可)。

採点の分水嶺: ①「**二重脅迫**」を明示 ②MFA未導入 + 使い回しの**両方** ③バックアップが同一・オンライン・書換可だった点 + イミュータブル/オフラインの二つ ④**Credential Access** と **Lateral Movement** を取り違えない ⑤Navigator を挙げられるか。



総合サマリー — 頻出ヒートマップ & 総括

出題可能性 × 難易度で攻撃・IR論点を俯瞰

SUMMARY

論点	出題可能性	難易度	対策語集
MITRE ATT&CK / TTP・キルチェーン	最有力	中	What/How/実装
ランサムウェア / 二重脅迫・バックアップ	最有力	中	イミュータブル/3-2-1
EDR / XDR / MDR	最有力	低	横断相関/運用代行
フォレンジック / 揮発性の順序	高	中	メモリ優先/ライブ保全
横展開 / Pass the Hash・LotL	高	高	再利用=横展開/振る舞い検知

総括: 攻撃・IR分野は**午前IIの用語定義**(ATT&CK・EDR/XDR/MDR・PtH・揮発性順)と、**午後の実務シナリオ**(ランサムウェアIR・SOC検知)の両輪で狙われる。全論点を**ATT&CKの戦術**で言語化し、対策は「MFA・イミュータブル/オフライン・XDR横断相関・振る舞い検知・ライブ保全」に集約して固めること。

※本デッキはAIが過去問傾向・最新動向をもとに作成した予想問題です。正解・解説・図解は最終確認を推奨します。